

Enci/ VENTAS

Guia de Administracion de Usuarios

Alta Operativa, Roles, Plataformas, Bloqueo de Acceso y Control de Cuentas

Version 1.0
Julio 2026
Aplicacion de Automatizacion de Fuerza de Ventas

Cliente	Enci / Enci Ventas
Representante receptor	Max
Equipo desarrollador	Grupo PLM - Universidad Tecnologica Metropolitana (UTEM)
Lider de equipo	Joshua Flores
Integrantes	Falon Berrios, Carolaine Palacios y Eliseo Poblete
Repositorio oficial del MVP web	Chumajer14/Encipharm
Tipo de documento	Guia operativa y administrativa para gestion de cuentas de usuario

ALTA Usuario registrado	ROL Permiso asignado	PLATAFORMA Web/App habilitada	BAJA Acceso bloqueado
----------------------------	-------------------------	----------------------------------	--------------------------

Naturaleza del documento

Esta guia define el procedimiento formal para administrar usuarios en Enci Ventas. Establece como dar de alta cuentas, asignar roles, habilitar plataformas, bloquear usuarios, revisar permisos y validar que cada cuenta acceda exclusivamente a las funciones permitidas por el backend.

Tabla de Contenidos

1. Introducción
2. Principios de administración de usuarios
3. Modelo de ciclo de vida de cuenta
4. Campos operativos del usuario
5. Alta operativa de usuarios
6. Asignación y cambio de rol
7. Habilitación por plataforma
8. Desactivación y baja de usuarios
9. Revisión periódica y gobierno de accesos
10. Validaciones técnicas esperadas
11. Casos de prueba administrativos
12. Riesgos y controles
13. Checklist de entrega y UAT

1. Introduccion

La administracion de usuarios en Enci Ventas es el proceso mediante el cual se controla quien puede ingresar al sistema, que rol tiene, que plataforma puede utilizar y que registros puede consultar o modificar. El sistema utiliza Firebase Auth para autenticar la identidad del usuario y Firestore para almacenar el perfil operativo, rol, estado activo y permisos de acceso por plataforma.

La cuenta no queda habilitada automaticamente para operar el sistema completo. Un usuario puede autenticarse correctamente con Google y, aun asi, quedar sin acceso funcional hasta que un administrador le asigne rol, active plataforma y confirme su estado operativo. Esta separacion reduce el riesgo de acceso indebido y permite operar un flujo de admision controlado antes de UAT o go-live.

Criterio central

Autenticacion no equivale a autorizacion. Firebase confirma identidad; el backend decide acceso efectivo usando rol, estado activo, propiedad del registro y permisos por plataforma.

2. Principios de administracion de usuarios

- Toda cuenta debe quedar asociada a un UID de Firebase Auth y a un documento operativo en la coleccion users.
- El rol inicial seguro para una cuenta nueva es sin_acceso, hasta que el administrador confirme su habilitacion.
- La autorizacion se aplica en backend; la interfaz solo oculta o muestra opciones segun experiencia de usuario.
- Un usuario inactivo no debe acceder a /me ni a endpoints protegidos, aunque conserve un token previamente emitido.
- Los permisos por plataforma deben revisarse por separado: webApp para CRM web y appMovil para app/PWA vendedor.
- Los cambios sensibles deben ser ejecutados por administradores y validados posteriormente con pruebas de acceso real.

Principio	Aplicacion practica	Resultado esperado
Menor privilegio	Asignar solo el rol requerido	Evita acceso superior innecesario
Bloqueo preventivo	Usar activo=false ante baja o duda	Corta acceso de forma inmediata
Separacion de identidad y rol	Login Google no habilita por si solo	Permite revision previa
Control por backend	Validar rol en API	Evita dependencia de controles visuales
Revision periodica	Auditar usuarios antes de UAT/go-live	Reduce cuentas olvidadas

3. Modelo de ciclo de vida de cuenta

El ciclo de vida de una cuenta comienza cuando el usuario inicia sesion con Google por primera vez. El backend sincroniza la identidad con Firestore y crea o actualiza el documento operativo. Desde ese momento, el administrador debe revisar la cuenta y completar su habilitacion de acuerdo con el rol esperado.

Etapas	Responsable	Descripcion	Estado esperado
Solicitud de acceso	Usuario / responsable interno	El usuario requiere ingreso al CRM web o app vendedor.	Pendiente de validacion
Primer login	Usuario	Ingresa con Google SSO y genera identidad Firebase.	UID creado

Etapa	Responsable	Descripcion	Estado esperado
Sincronizacion	Backend	Crea o actualiza documento users en Firestore.	Perfil registrado
Revision administrativa	Admin	Confirma correo, cargo, rol y plataforma.	Habilitacion controlada
Operacion	Usuario	Accede segun rol y plataforma habilitada.	Cuenta activa
Cambio	Admin	Ajusta rol, zona, rango, tema, idioma o plataforma.	Permisos actualizados
Baja	Admin	Marca activo=false y retira acceso cuando corresponda.	Acceso bloqueado

4. Campos operativos del usuario

El documento de usuario contiene datos de identidad, permisos funcionales, preferencias y estado operativo. Los campos deben mantenerse consistentes para que la autenticacion, autorizacion y navegacion por rol funcionen de forma predecible.

Campo	Tipo / valor esperado	Uso operativo
uid	string	Identificador unico de Firebase Auth y clave del documento de usuario.
email	Email valido	Correo autenticado desde Google y referencia principal de identidad.
nombre	Texto	Nombre visible en interfaz y administracion.
rol	sin_acceso, vendedor, supervisor, admin	Define permisos funcionales dentro del backend.
cargo	Texto operativo	Cargo o descripcion visible para administracion.
rango	Sin acceso, Solo lectura, Vendedor, Gerente, Administrador	Clasificacion laboral visible o administrativa.
zona	Zona norte, centro, sur, oriente	Segmentacion comercial o territorial.
appMovil	boolean	Permite o bloquea uso desde cliente movil/app vendedor.
webApp	boolean	Permite o bloquea uso desde CRM web.
theme	dark / light	Preferencia visual del usuario.
language	es / en / pt	Preferencia de idioma.
activo	boolean	Control maestro de bloqueo o habilitacion.
createdAt	timestamp	Fecha de creacion del perfil operativo.
updatedAt	timestamp	Fecha de ultima modificacion del perfil.

Campos sensibles

rol, activo, appMovil y webApp deben tratarse como campos sensibles. Una asignacion erronea puede exponer datos, habilitar plataformas no requeridas o conceder privilegios administrativos.

5. Alta operativa de usuarios

El alta operativa consiste en transformar una identidad autenticada en una cuenta funcional autorizada. No debe saltarse la revision administrativa, especialmente antes de pruebas con usuarios reales o antes de la salida controlada a produccion.

5.1 Flujo de alta

- 1 El usuario ingresa al sistema con Google SSO desde la web o plataforma habilitada.

- 2 Firebase Auth entrega un ID Token al frontend.
- 3 El frontend envía el token al backend en el encabezado Authorization: Bearer <firebase_id_token>.
- 4 El backend valida el token mediante Firebase Admin.
- 5 Si el usuario no existe en Firestore, se crea un perfil base con rol sin_acceso, plataformas deshabilitadas y activo=true.
- 6 El administrador revisa el usuario creado, confirma identidad y asigna rol operativo.
- 7 El administrador habilita webApp, appMovil o ambas plataformas según corresponda.
- 8 El usuario vuelve a iniciar sesión y valida que visualiza solo las rutas esperadas.

5.2 Registro inicial recomendado

Campo	Valor inicial recomendado	Justificación
rol	sin_acceso	Evita acceso automático no revisado.
activo	true	Permite que el administrador complete habilitación sin bloquear identidad.
webApp	false	Requiere autorización explícita para CRM web.
appMovil	false	Requiere autorización explícita para app/PWA vendedor.
theme	dark	Preferencia visual por defecto.
language	es	Idioma base del proyecto.

5.3 Checklist de alta

- Confirmar correo corporativo o correo autorizado por el cliente.
- Confirmar nombre visible y cargo del usuario.
- Confirmar rol solicitado: vendedor, supervisor o admin.
- Confirmar plataforma requerida: CRM web, app vendedor o ambas.
- Probar login con Google SSO.
- Probar endpoint /me o carga inicial del frontend.
- Verificar que el usuario solo pueda ver las pantallas que corresponden a su rol.
- Registrar cualquier desviación como incidencia UAT o ajuste administrativo.

6. Asignación y cambio de rol

El cambio de rol modifica el alcance funcional del usuario. Debe realizarse solo cuando exista confirmación previa del responsable operativo, ya que el rol determina visibilidad de datos, acceso a administración y permisos de escritura.

Rol	Uso permitido	Restricciones principales
sin_acceso	Cuenta autenticada pero no habilitada para operar.	No debe acceder a funciones protegidas del sistema.
vendedor	Gestiona clientes, interacciones, oportunidades y propuestas propias.	No debe ver ni modificar registros asignados a otros vendedores.
supervisor	Consulta información consolidada y funciones de supervisión.	No reemplaza al admin para cambios sensibles.
admin	Administra usuarios, roles, estados, importaciones y configuración operativa.	Debe asignarse de forma excepcional y controlada.

6.1 Procedimiento de cambio

- 1 Identificar al usuario por correo y UID.
- 2 Confirmar con el responsable del cliente el rol requerido.
- 3 Revisar rol actual y plataformas habilitadas.
- 4 Actualizar rol desde la vista administrativa o mediante endpoint autorizado.
- 5 Solicitar cierre de sesión y nuevo ingreso del usuario si la interfaz mantiene estado anterior.
- 6 Probar acceso a una ruta permitida y a una ruta restringida.
- 7 Registrar fecha, motivo y responsable del cambio cuando aplique.

6.2 Endpoints administrativos relacionados

Operacion	Endpoint	Rol requerido	Uso
Listar usuarios	GET /users	supervisor o superior	Revisar usuarios activos o filtrados.
Consultar usuario	GET /users/{uid}	supervisor o superior	Obtener detalle de una cuenta.
Actualizar usuario	PATCH /users/{uid}	admin	Modificar datos operativos sensibles.
Cambiar rol	PATCH /users/{uid}/role	admin	Asignar admin, supervisor, vendedor o sin_acceso.
Cambiar estado	PATCH /users/{uid}/status	admin	Activar o desactivar cuenta.
Preferencias propias	PATCH /users/me/preferences	usuario autenticado	Cambiar tema o idioma propio.

Advertencia operativa

No usar controles temporales de desarrollo para asignar roles en UAT o producción. Cualquier endpoint temporal debe estar deshabilitado fuera de development.

7. Habilitación por plataforma

El sistema distingue el acceso desde web y desde cliente móvil/app vendedor. Esta separación permite que un usuario pueda operar solo una plataforma sin quedar autorizado automáticamente en la otra.

Campo	Plataforma	Header / criterio	Resultado
webApp	CRM web	X-Enci-Client: web o valor omitido	Permite acceso a rutas web protegidas.
appMovil	App/PWA vendedor	X-Enci-Client: mobile, movil, app, app_movil o app-movil	Permite acceso desde cliente móvil.

7.1 Escenarios permitidos

Escenario	webApp	appMovil	Interpretación
Usuario de oficina	true	false	Puede usar CRM web, pero no app móvil.
Vendedor en terreno	true	true	Puede usar CRM web y app vendedor si el rol lo permite.
Acceso móvil exclusivo	false	true	Puede operar app vendedor, sin CRM web.
Cuenta bloqueada por plataforma	false	false	Aunque tenga rol, no debe ingresar por plataforma.

8. Desactivación y baja de usuarios

La desactivación es el mecanismo principal para cortar acceso a una cuenta sin eliminar su historial. Debe aplicarse cuando el usuario deja el equipo, pierde autorización, requiere bloqueo preventivo o se detecta uso incorrecto.

Motivo	Acción recomendada	Efecto esperado
Salida del equipo	activo=false y retirar plataformas	Usuario bloqueado en backend.
Cambio de funciones	Ajustar rol y plataformas	Reduce privilegios a lo necesario.
Incidente o sospecha	activo=false inmediato	Mitiga uso indebido mientras se revisa.
Cuenta duplicada	Conservar una activa y bloquear duplicada	Evita confusión y trazabilidad rota.
Fin de UAT	Bloquear cuentas temporales	Reduce superficie luego de pruebas.

8.1 Checklist de baja

- 1 Localizar usuario por email y UID.
- 2 Cambiar activo=false.
- 3 Retirar webApp y appMóvil si corresponde.
- 4 Confirmar que /me o endpoints protegidos respondan 403 para la cuenta.
- 5 Verificar que la cuenta no pueda operar clientes, oportunidades, propuestas ni RAG.
- 6 Registrar fecha, responsable y motivo de baja en el control operativo del cliente.

No eliminar historial

Para mantener trazabilidad comercial y técnica, la baja operativa debe bloquear acceso sin borrar registros históricos asociados a clientes, interacciones, oportunidades, propuestas o conversaciones.

9. Revisión periódica y gobierno de accesos

La administración de usuarios debe revisarse de forma programada. Esto evita cuentas activas sin responsable, roles superiores innecesarios y accesos por plataforma que ya no corresponden.

Momento	Revisión mínima	Decisión esperada
Antes de UAT	Usuarios de prueba, roles, plataformas y estado activo.	Mantener solo cuentas necesarias.
Antes de go-live	Cuentas reales del cliente y roles definitivos.	Cerrar permisos temporales.
Después de cambios de equipo	Altas, bajas y cambios de cargo.	Actualizar rol o desactivar.
Revisión mensual	Admins activos, supervisores y vendedores sin uso.	Reducir privilegios innecesarios.
Post incidente	Cuenta afectada, plataformas y actividad reciente.	Bloquear o corregir permisos.

10. Validaciones técnicas esperadas

Cada cambio administrativo relevante debe validarse técnicamente para asegurar que backend, frontend y Firestore aplican el estado actualizado. La validación no debe limitarse a mirar la interfaz; debe comprobarse que la API responde conforme al rol y estado del usuario.

Validacion	Metodo	Resultado esperado
Token valido	Login Google y llamada a /me	Retorna uid, email, rol y activo=true.
Usuario sin acceso	Cuenta con rol sin_acceso	Endpoints protegidos deben rechazar operacion.
Usuario inactivo	activo=false	Backend responde 403 aunque el token sea valido.
Vendedor propio	GET /clientes	Lista solo clientes asociados al vendedor.
Vendedor ajeno	GET /clientes/{id} de otro vendedor	Backend responde 403.
Supervisor	GET /dashboard/supervisor	Puede consultar metricas consolidadas.
Admin	PATCH /users/{uid}/role	Puede cambiar rol operativo.
Plataforma bloqueada	Header X-Enci-Client segun plataforma	Backend rechaza si webApp/appMovil=false.

11. Casos de prueba administrativos

Caso	Precondicion	Pasos	Resultado esperado
ADM-01 Alta vendedor	Usuario creado con sin_acceso	Asignar rol vendedor, webApp=true, activo=true; probar login.	Accede a vista vendedor y registros propios.
ADM-02 Alta supervisor	Usuario autenticado	Asignar rol supervisor y webApp=true; probar dashboard supervisor.	Accede a metricas consolidadas.
ADM-03 Alta admin	Solicitud aprobada	Asignar admin solo a cuenta autorizada; probar /users.	Puede administrar usuarios.
ADM-04 Bloqueo usuario	Cuenta activa	Cambiar activo=false; probar /me.	Respuesta 403 o bloqueo funcional.
ADM-05 Cambio de rol	Cuenta vendedor	Cambiar a supervisor; reingresar.	Visualiza funciones supervisor, no admin.
ADM-06 Plataforma web bloqueada	webApp=false	Intentar acceso desde web.	Acceso rechazado por backend.
ADM-07 App movil bloqueada	appMovil=false	Intentar acceso con header mobile.	Acceso rechazado por backend.
ADM-08 Usuario temporal UAT	Cuenta de prueba	Habilitar durante UAT y bloquear al finalizar.	Cuenta queda inactiva post prueba.

12. Riesgos y controles

Riesgo	Impacto	Control recomendado
Asignar admin por error	Acceso amplio a usuarios y configuracion.	Revisar dos veces antes de guardar y limitar cantidad de admins.
Dejar usuarios antiguos activos	Superficie de ataque y uso indebido.	Revision periodica y baja inmediata.
Habilitar appMovil sin necesidad	Acceso fuera de oficina o terreno no autorizado.	Activar solo por requerimiento operacional.
Rol correcto pero plataforma incorrecta	Bloqueos o exposicion funcional no deseada.	Verificar webApp/appMovil en cada alta.
Cuenta duplicada	Trazabilidad comercial fragmentada.	Consolidar identidad y desactivar duplicados.
Cambios no registrados	Dificulta auditoria y soporte.	Registrar fecha, motivo y responsable.

Control minimo antes de entrega

Antes de entregar el sistema al cliente, se debe revisar que no existan usuarios administrativos innecesarios, cuentas temporales activas, usuarios sin rol definido que puedan operar, ni plataformas habilitadas sin justificacion.

13. Checklist de entrega y UAT

Este checklist debe ejecutarse antes de la validacion formal con usuarios reales. Su objetivo es confirmar que el modulo de administracion de usuarios no solo existe, sino que opera de forma controlada, trazable y alineada con los roles definidos para el MVP.

N.	Control	Responsable	Estado
1	Listar usuarios activos y revisar roles asignados.	Admin / equipo PLM	Pendiente UAT
2	Confirmar que usuarios nuevos parten sin_acceso hasta habilitacion.	Admin	Pendiente UAT
3	Validar al menos un usuario vendedor real.	Cliente / PLM	Pendiente UAT
4	Validar al menos un usuario supervisor real.	Cliente / PLM	Pendiente UAT
5	Confirmar que el rol admin queda limitado a responsables autorizados.	Cliente	Pendiente UAT
6	Probar bloqueo activo=false.	PLM	Pendiente UAT
7	Probar restriccion webApp y appMovil.	PLM	Pendiente UAT
8	Bloquear cuentas temporales no necesarias.	Admin	Pendiente go-live
9	Registrar observaciones de administracion de usuarios.	Cliente / PLM	Pendiente cierre

Cierre del documento

La administracion de usuarios se considera apta para UAT cuando las altas, cambios de rol, cambios de plataforma y bajas se ejecutan correctamente desde backend y se confirma que las cuentas no acceden a informacion fuera de su rol o propiedad.